

Proyecto: VALGREEN — Sistema de Gestión de Repostería

Documento: Autenticacion Autorizacion

Generado el: 2026-09-23 16:27

PROMPT 6 — Pruebas de autenticación y autorización

Proyecto: VALGREEN — Sistema de Gestión de Repostería

Usuarios y roles existentes (derivados del código)

Rol	Permisos	Rutas autorizadas
Administrador	Acceso total	TODAS: /dashboard, /productos, /stock, /usuarios, /ventas, /pedidos, /clientes
Vendedor	Acceso limitado	/dashboard, /stock (solo index/consulta), /ventas, /pedidos, /clientes*
No autenticado	Sin acceso	/, /login

Funcionalidades protegidas

#	Funcionalidad	Ruta	HTTP	Roles permitidos
1	Listar productos	GET /productos	GET	Administrador
2	Crear producto	GET/POST /productos/create, /productos	GET/POST	Administrador
3	Registrar movimiento stock	GET/POST /stock/create, /stock	GET/POST	Administrador
4	Gestionar usuarios (listar, crear, editar, estado)	/usuarios*	*	Administrador
5	Consultar stock	GET /stock	GET	Administrador, Vendedor
6	Gestión ventas	/ventas*	*	Administrador, Vendedor
7	Gestión pedidos	/pedidos*	*	Administrador, Vendedor

#	Funcionalidad	Ruta	HTTP	Roles permitidos
8	Gestión clientes	/clientes*	*	Administrador, Vendedor
9	Dashboard	GET /dashboard	GET	Administrador, Vendedor

Casos de prueba AA (Autenticación y Autorización)

AA-001 Inicio de sesión exitoso como Administrador

- **ID:** AA-001
- **Requisito:** RF-001
- **Tipo:** AUT
- **Precondiciones:** Usuario admin existe, rol_id=1, estado=1. Password hashado.
- **Datos:** usuario="admin", password="Admin123"
- **Pasos:** 1. Navegador privado → /login. 2. Llenar credenciales. 3. Clic Iniciar sesión. 4. Inspeccionar cookies sesión.
- **Resultado esperado:** 302 → 200 /dashboard. Dashboard Admin muestra "Ventas hoy", "Pedidos activos", "Usuarios activos", "Stock bajo". Cookie laravel_session presente.
- **Resultado obtenido:**
- **Estado:** PENDIENTE
- **Evidencia:** Captura dashboard + URL + cookie

AA-002 Rechazo por contraseña incorrecta

- **ID:** AA-002
- **Requisito:** RF-003
- **Tipo:** AUT
- **Datos:** usuario="admin", password="Incorrecta123"
- **Resultado esperado:** Permanece /login; alerta roja "No se pudo iniciar sesión. Usuario o contraseña incorrectos." old(usuario) conserva valor.
- **Resultado obtenido:**
- **Estado:** PENDIENTE

AA-003 Usuario inexistente

- **ID:** AA-003

- **Requisito:** RF-003
- **Tipo:** AUT
- **Datos:** usuario="usuario_quexisteno_xyz", password="Cualquiera1"
- **Resultado esperado:** Mismo comportamiento que contraseña incorrecta (anti-enumeración). NO mensaje distinto como "este usuario no existe".
- **Resultado obtenido:**
- **Estado:** PENDIENTE
- **Observaciones:** Verificar anti-enumeración

AA-004 Formulario login vacío

- **ID:** AA-004
- **Requisito:** RF-003
- **Tipo:** AUT
- **Datos:** usuario="", password=""
- **Pasos:** Enviar formulario sin llenar
- **Resultado esperado:** 2 errores: "campo usuario obligatorio", "campo password obligatorio"
- **Resultado obtenido:**
- **Estado:** PENDIENTE

AA-005 Cierre de sesión invalida la sesión

- **ID:** AA-005
- **Requisito:** RF-004
- **Tipo:** SES+AUT
- **Precondiciones:** Sesión admin iniciada
- **Pasos:** 1. Clic logout (POST /logout). 2. Navegar manualmente /dashboard. 3. Botón atrás navegador.
- **Resultado esperado:** Paso 1 → redirect /login. Cookie sesión regenerada/vaciada. Paso 2 → redirect /login. Paso 3 → tras refrescar pide login.
- **Resultado obtenido:**
- **Estado:** PENDIENTE
- **Evidencia:** 2 capturas (logout + bloqueo dashboard)

AA-006 Acceso URL protegida sin autenticación

- **ID:** AA-006
- **Requisito:** RF-007

- **Tipo:** AUTZ
- **Precondiciones:** Sesión NO iniciada (navegador privado)
- **Rutas a probar:** GET /dashboard, /productos, /productos/create, /stock, /ventas, /ventas/create, /pedidos, /pedidos/create, /clientes, /clientes/create, /usuarios, /usuarios/create, /stock/create
- **Pasos:** Para cada URL, acceso directo por barra
- **Resultado esperado:** TODAS → 302 Location: /login. Ninguna carga contenido real.
- **Resultado obtenido:**
- **Estado:** PENDIENTE

AA-007 Vendedor intenta acceder rutas Administrador

- **ID:** AA-007
- **Requisito:** RF-006
- **Tipo:** AUTZ
- **Precondiciones:** Sesión Vendedor iniciada (rol_id=2)
- **Rutas (GET + POST/PUT):** /productos, /productos/create, POST /productos, /stock/create, POST /stock, /usuarios, /usuarios/create, POST /usuarios, GET /usuarios/X/edit, PUT /usuarios/X, PUT /usuarios/X/estado
- **Pasos:** GET directo URL. POST/PUT con cookie sesión + CSRF (DevTools o Postman)
- **Resultado esperado:** TODAS → HTTP 403 "No tienes permiso para acceder a esta sección". Cero escrituras en BD.
- **Resultado obtenido:**
- **Estado:** PENDIENTE

AA-008 El menú solo muestra opciones permitidas por rol

- **ID:** AA-008
- **Requisito:** RF-005, RF-006
- **Tipo:** AUTZ
- **Precondiciones:** Sesiones Admin y Vendedor listas
- **Pasos:** 1. Login Admin, inspeccionar menú. 2. Logout. 3. Login Vendedor, inspeccionar menú.
- **Resultado esperado:** Admin ve Dashboard, Productos, Stock, Usuarios, Ventas, Pedidos, Clientes. Vendedor NO ve Productos, Usuarios, Registrar movimiento Stock.
- **Resultado obtenido:**
- **Estado:** PENDIENTE
- **Evidencia:** Captura menú Admin + Vendedor

AA-009 Acceso después de cerrar sesión

- **ID:** AA-009
- **Requisito:** RF-004, RF-007
- **Tipo:** SES+AUTZ
- **Precondiciones:** Admin acaba de hacer logout correcto
- **Pasos:** En misma pestaña navegar /dashboard, /pedidos/create, /usuarios, /ventas
- **Resultado esperado:** Todas redirigen a /login. Ctrl+F5 asegura que no es caché.
- **Resultado obtenido:**
- **Estado:** PENDIENTE

AA-010 Manejo de sesión y regeneración de token

- **ID:** AA-010
- **Requisito:** RNF-001, RNF-002
- **Tipo:** SES
- **Pasos:** 1. Login exitoso. 2. Copiar valor _token CSRF de un formulario. 3. Logout. 4. Volver login. 5. Comparar _token nuevo. 6. Con sesión abierta, eliminar cookie laravel_session manualmente y refrescar /dashboard.
- **Resultado esperado:** Paso 1: session()->regenerate() (AuthController L36). Tokens CSRF distintos. Paso 6: Sistema trata usuario como invitado → redirect login.
- **Resultado obtenido:**
- **Estado:** PENDIENTE

AA-011 Operación crítica: Vendedor PUT estado usuario

- **ID:** AA-011
- **Requisito:** RF-005, RN-09, RN-10
- **Tipo:** AUTZ
- **Precondiciones:** Login Vendedor. Usuario id=5 existe activo.
- **Pasos:** Con DevTools o Postman construir PUT /usuarios/5/estado con cookie sesión Vendedor + CSRF válido.
- **Resultado esperado:** HTTP 403 Forbidden de RoleMiddleware. Estado usuario NO cambia en BD (SELECT confirma).
- **Resultado obtenido:**
- **Estado:** PENDIENTE
- **Evidencia:** Captura 403 + SELECT antes/después

AA-012 Usuario desactivado mientras tenía sesión abierta

- **ID:** AA-012

- **Requisito:** RF-002
- **Tipo:** AUT
- **Precondiciones:** 2 navegadores. Nav A = Admin. Nav B = Usuario Vendedor "vendedor1" logueado OK.
- **Pasos:** 1. Nav A: desactivar "vendedor1". 2. Nav B: pulsar enlace "Ventas" o cualquier acción.
- **Resultado esperado:** [REQ-VERIFICACIÓN] Documentar comportamiento real. Si cierra sesión → OK. Si sigue operando → se registra como observación (sesión no valida estado en cada request por defecto).
- **Resultado obtenido:**
- **Estado:** PENDIENTE
- **Observaciones:** Comportamiento depende de middleware adicional de estado

AA-013 Contraseña almacenada hasheada (seguridad)

- **ID:** AA-013
- **Requisito:** RNF-001
- **Tipo:** AUT (seguridad)
- **Precondiciones:** Usuario "anagomez" creado (contraseña "Ana1234").
- **Pasos:** 1. MySQL CLI. 2. USE valgreen_test. 3. SELECT usuario, password FROM usuarios WHERE usuario='anagomez';
- **Resultado esperado:** password NO es "Ana1234". Empieza con "\$2y\$" (Bcrypt) o "\$argon". ~60 caracteres.
- **Resultado obtenido:**
- **Estado:** PENDIENTE
- **Evidencia:** Captura SELECT SQL

AA-014 Intento SQL Injection en login

- **ID:** AA-014
- **Requisito:** RNF-002
- **Tipo:** AUT (seguridad)
- **Datos:** usuario="admin' OR '1'='1", password="cualquiera"
- **Pasos:** Login con datos
- **Resultado esperado:** Eloquent where usa PDO prepared statements. NO se loguea. Error normal credenciales.
- **Resultado obtenido:**
- **Estado:** PENDIENTE

AA-015 CSRF protection en POST (login y logout)

- **ID:** AA-015
- **Requisito:** RNF-002
- **Tipo:** AUT (seguridad)
- **Precondiciones:** Página /login cargada.
- **Pasos:** Con Postman enviar POST /login con usuario y password correctos PERO SIN campo _token.
- **Resultado esperado:** HTTP 419 Page Expired (CSRF mismatch). NO se inicia sesión.
- **Resultado obtenido:**
- **Estado:** PENDIENTE

 Resumen: 15 casos de AA

ID	Nombre	Requisito	Tipo
AA-001	Login exitoso Admin	RF-001	AUT
AA-002	Contraseña incorrecta	RF-003	AUT
AA-003	Usuario inexistente	RF-003	AUT
AA-004	Campos vacíos	RF-003	AUT
AA-005	Logout correcto	RF-004	SES
AA-006	URL protegidas sin autenticación	RF-007	AUTZ
AA-007	Vendedor → rutas Admin	RF-006	AUTZ
AA-008	Menú visible por rol	RF-005/006	AUTZ
AA-009	Acceso post-logout	RF-004/007	SES
AA-010	Sesión segura + CSRF regeneración	RNF-002	SES
AA-011	Vendedor PUT estado usuario (op crítica)	RF-005/006	AUTZ
AA-012	Usuario desactivado en sesión [REQ-VER]	RF-002	AUT
AA-013	Password hasheado en BD	RNF-001	SEG
AA-014	SQLi en login	RNF-002	SEG
AA-015	CSRF protection	RNF-002	SEG